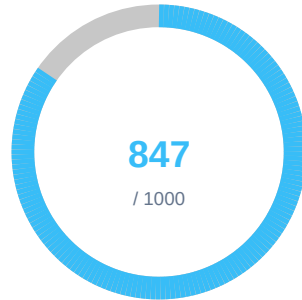


Code Hardener

ATTESTATION CERTIFICATE



bulletproof-governance-plugin

Scan ae9709d8 | Branch: main | Jul 24, 2026

Attestation ID

cfc8c76b-a2cd-43a1-86be-...

Type

in-toto

Subject

bulletproof-governance-plugin

Created

Jul 24, 2026, 4:26 PM

Subject Digest

sha256:e1f702b61e63c7c8939db80e7033fc17ee368e4338acce11ddc9a986...

Signature Status

CRYPTOGRAPHICALLY SIGNED

Algorithm: Ed25519 (Local Signing Key)

Signature

ybmMYJjzpkJDlcRV2qTCew9x7NrZgYHTRS2C49QXaH5vyKfUtEj2fVaKLFBfD+8N
B5Bb08sUptmu9pWts01TCQ==

This attestation certifies the security scan was performed and results were recorded with cryptographic integrity.

Scan Report — bulletproof-governance-plugin

Branch: main | Status: completed | Jul 24, 2026

847 / 1000 Score — Quality: good

Scan Details

Profile: standard
Duration: 18s
Started: Jul 24, 2026, 4:26 PM
Completed: Jul 24, 2026, 4:26 PM
Files Analyzed: 68
Scanners Run: 11 of 12
Open Findings: 71
Resolved / Suppressed:0
Total Detected: 71
Codebase: Python: 46 files | Config: 13 files | Markdown: 5 files | Shell: 1 files

0 Critical 0 High 61 Medium 8 Low 2 Info

Scanner Results

12 tools executed — 6 passed | 5 with open findings | 1 not applicable | 0 errors

Scanner	Category	Outcome	Findings	Duration	Files Scanned
trivy	SCA	FAIL	1	2s	2
gitleaks	Secrets	PASS	0	0s	68
opengrep	SAST	FAIL	3	6s	47
checkov	IaC	PASS	0	3s	13
grype	SCA	PASS	0	3s	68
syft	SBOM	FAIL	7	1s	7
package-validator	AI Code Quality	PASS	0	0s	1

oxlint	Code Quality	N/A	0	0s	47
ruff	Code Quality	FAIL	59	0s	46
actionlint	CI/CD Security	PASS	0	0s	13
jscpd	Code Quality	PASS	0	0s	46
typos	Code Quality	FAIL	1	0s	68

Scanner Evidence & Audit Trail

trivy (SCA)

FINDINGS

Scan Scope: Scanned 2 target(s): pip

Files Analyzed: 2

Rules Checked: 4

Checks Performed:

- Vulnerability scanning
- Misconfiguration detection
- Secret detection
- License compliance

Standards: CVE/NVD, OWASP Top 10 (A06), CIS Benchmarks, NIST SP 800-53

Methodology:

Scans filesystem for package manifests and lock files, matches installed packages against vulnerability databases (NVD, GitHub Advisory, vendor-specific). Also checks for misconfigurations and secrets using built-in rules.

Targets Analyzed:

requirements.txt, Loose File License(s)

gitleaks (Secrets)

PASS

Scan Scope: Working directory scanned for 150+ secret patterns with entropy analysis

Configuration: Custom gitleaks.toml

Files Analyzed: 68

Rules Checked: 150

Checks Performed:

- AWS credential detection
- API key detection
- Private key detection
- Generic secret patterns
- High-entropy string analysis
- Token detection

Standards: CWE-798, CWE-259, OWASP Top 10 (A07)

Methodology:

Regex-based pattern matching against 150+ secret patterns with entropy analysis. Scans current file contents and optionally git commit history. Applies allowlists and custom rules to reduce false positives. Secrets are redacted in output.

opengrep (SAST)

FINDINGS

Scan Scope: Multi-language SAST with auto, security-audit, owasp-top-ten, cwe-top-25, r2c-security-audit, and secrets rulesets

Configuration: Custom semgrep-rules.yml + default rulesets

Files Analyzed: 47

Rules Checked: 3

Checks Performed:

- OWASP Top 10 patterns

- Security audit rules
- Secrets detection
- Injection patterns
- XSS patterns
- Insecure crypto usage

Standards: OWASP Top 10, CWE Top 25, SANS Top 25

Methodology:

Pattern-based static analysis using Semgrep rule engine with auto, security-audit, owasp-top-ten, and secrets rulesets. Matches AST patterns against known vulnerability signatures.

checkov (IaC)

PASS

Scan Scope: IaC security analysis — 0 files, 0 checks (0 passed, 0 failed), frameworks: auto-detected

Configuration: Custom .checkov.yaml

Files Analyzed: 13

Checks Performed:

- Terraform misconfigurations
- CloudFormation template issues
- Kubernetes manifest hardening
- Dockerfile best practices
- Helm chart security
- GitHub Actions security
- GitLab CI security
- Secrets in IaC files

Standards: CIS Benchmarks, NIST SP 800-53, SOC 2, PCI-DSS, HIPAA

Methodology:

Graph-based static analysis of infrastructure-as-code files. Parses IaC definitions, builds resource graphs, and checks 1000+ built-in policies covering security, networking, encryption, and compliance.

grype (SCA)

PASS

Scan Scope: SCA analysis: 0 unique CVEs across 0 vulnerable packages (filesystem)

Configuration: Grype with --by-cve deduplication and --add-cpes-if-none

Files Analyzed: 68

Checks Performed:

- CVE vulnerability matching
- Dependency version analysis
- CPE-based matching
- Advisory cross-referencing
- Fix availability detection

Standards: CVE/NVD, OWASP Top 10 (A06), GHSA

Methodology:

Generates SBOM using Syft, then matches all identified packages against vulnerability databases (NVD, GitHub Advisories, OS vendor databases). Reports CVEs with severity, fix versions, and references.

syft (SBOM)

FINDINGS

Scan Scope: SBOM of 7 packages across 1 language(s): python

Configuration: Syft with JSON + CycloneDX output for SBOM standards compliance

Files Analyzed: 7

Rules Checked: 4

Checks Performed:

- SBOM generation (Syft JSON + CycloneDX)
- License compliance analysis
- Copyleft license detection (AGPL, GPL, MPL)
- Weak copyleft classification (LGPL)

- Unknown license flagging
- Package URL (PURL) generation
- CPE generation

Standards: NTIA SBOM Minimum Elements, CycloneDX, SPDX, Executive Order 14028

Methodology:

Catalogs software packages by parsing package manifests, lock files, and installed package databases. Generates standardized SBOM in CycloneDX or SPDX format for supply chain visibility.

package-validator (AI Code Quality)
PASS

Scan Scope: Validated 5 packages across 1 dependency file(s)

Configuration: Concurrency: 10, Timeout: 5000ms per request

Files Analyzed: 1

Rules Checked: 1

Checks Performed:

- npm registry existence validation
- PyPI registry existence validation
- Go module proxy existence validation
- Slopsquatting risk detection
- Hallucinated dependency identification

Standards: CWE-829, OWASP A08:2021, SLSA Supply Chain Security

Methodology:

Parses dependency manifests and validates each package exists in its respective registry (npm, PyPI, Go proxy) via HTTP HEAD requests. Non-existent packages are flagged as hallucinated — a common AI code generation artifact that creates supply chain attack vectors.

oxlint (Code Quality)
N/A

Scan Scope: JavaScript (.js, .jsx) and TypeScript (.ts, .tsx) source files

Files Analyzed: 47

Checks Performed:

- Code correctness checks
- Suspicious code detection
- Performance anti-patterns
- Import/export validation

Standards: CWE, ESLint Core Rules

Methodology:

Rust-based linter that performs AST analysis of JS/TS files at high speed. Detects correctness issues, suspicious patterns, and performance anti-patterns.

ruff (Code Quality)
FINDINGS

Scan Scope: Python linting and security analysis via Ruff

Configuration: Default Ruff rules

Files Analyzed: 46

Checks Performed:

- Pyflakes error detection
- pycodestyle enforcement
- flake8-bandit security checks
- isort import ordering
- pep8-naming conventions
- pyupgrade modernization
- flake8-bugbear bug detection
- flake8-comprehensions optimization

Standards: PEP 8, PEP 257, CWE, OWASP Top 10

Methodology:

Rust-based Python linter implementing 800+ rules from flake8, pylint, isort, and others. 10-100x faster than traditional Python linters.

actionlint (CI/CD Security)

PASS

Scan Scope: .github/workflows/*.yaml files

Files Analyzed: 13

Checks Performed:

- Workflow syntax validation
- Action version pinning checks
- Shell script validation
- Expression type checking
- Permissions analysis

Standards: GitHub Actions Security Best Practices, CWE-78

Methodology:

Static analysis of GitHub Actions workflow files. Validates syntax, checks for unpinned action versions, analyzes shell scripts for errors, and verifies expression types.

jscpd (Code Quality)

PASS

Scan Scope: All source files across supported languages

Files Analyzed: 46

Checks Performed:

- Cross-file duplicate detection
- Code clone identification
- Duplication percentage calculation

Standards: ISO/IEC 25010 (Maintainability)

Methodology:

Token-based analysis to detect copy-pasted code blocks across files and languages. Reports duplication percentage and identifies specific cloned regions.

typos (Code Quality)

FINDINGS

Scan Scope: All files in project directory

Files Analyzed: 68

Checks Performed:

- Source code spelling analysis
- Identifier typo detection
- Comment typo detection
- String literal typo detection

Standards: ISO/IEC 25010 (Maintainability)

Methodology:

Fast, low-false-positive spell checker designed for source code. Checks identifiers, strings, and comments against a curated dictionary.

Open Findings (71)

ruff

Code Quality | 59 findings | Ultra-fast Python linter (pyflakes, pycodestyle, flake8-bandit)

Severity	Title	File	CWE / Rule
MEDIUM	Ruff F401: `datetime.timezone` imported but unused	tests/test_trust_broker.py:5	RUFF-F401

``datetime.timezone` imported but unused`

Fix: Auto-fix available: Remove unused import (applicability: safe)

MEDIUM Ruff F401: ``datetime.datetime` imported but unused` tests/test_trust_broker.py:5 RUFF-F401
``datetime.datetime` imported but unused`
Fix: Auto-fix available: Remove unused import (applicability: safe)

MEDIUM Ruff F401: ``json` imported but unused` tests/test_trust_broker.py:2 RUFF-F401
``json` imported but unused`
Fix: Auto-fix available: Remove unused import: ``json`` (applicability: safe)

MEDIUM Ruff F401: ``pathlib.Path` imported but unused` tests/test_policy_engine.py:4 RUFF-F401
``pathlib.Path` imported but unused`
Fix: Auto-fix available: Remove unused import: ``pathlib.Path`` (applicability: safe)

MEDIUM Ruff F401: ``os` imported but unused` tests/test_policy_engine.py:3 RUFF-F401
``os` imported but unused`
Fix: Auto-fix available: Remove unused import: ``os`` (applicability: safe)

MEDIUM Ruff F401: ``json` imported but unused` tests/test_policy_engine.py:2 RUFF-F401
``json` imported but unused`
Fix: Auto-fix available: Remove unused import: ``json`` (applicability: safe)

MEDIUM Ruff F401: ``unittest.mock.patch` imported but unused` tests/test_memory_integrity.py:4 RUFF-F401
``unittest.mock.patch` imported but unused`
Fix: Auto-fix available: Remove unused import: ``unittest.mock.patch`` (applicability: safe)

MEDIUM Ruff F401: ``pathlib.Path` imported but unused` tests/test_memory_governor.py:3 RUFF-F401
``pathlib.Path` imported but unused`
Fix: Auto-fix available: Remove unused import: ``pathlib.Path`` (applicability: safe)

MEDIUM Ruff F401: ``os` imported but unused` tests/test_memory_governor.py:2 RUFF-F401
``os` imported but unused`
Fix: Auto-fix available: Remove unused import: ``os`` (applicability: safe)

MEDIUM Ruff F401: ``governance.lib.manifest.DEFAULT_RESTRICTI...`` tests/test_manifest.py:87 RUFF-F401
``governance.lib.manifest.DEFAULT_RESTRICTIVE_MANIFEST` imported but unused`
Fix: Auto-fix available: Remove unused import: ``governance.lib.manifest.DEFAULT_RESTRICTIVE_MANIFEST`` (applicability: safe)

MEDIUM Ruff F401: ``governance.lib.manifest.load_static_manif...`` tests/test_manifest.py:74 RUFF-F401
``governance.lib.manifest.load_static_manifest` imported but unused`
Fix: Auto-fix available: Remove unused import: ``governance.lib.manifest.load_static_manifest`` (applicability: safe)

MEDIUM Ruff F401: ``tempfile` imported but unused` tests/test_manifest.py:4 RUFF-F401
``tempfile` imported but unused`
Fix: Auto-fix available: Remove unused import: ``tempfile`` (applicability: safe)

MEDIUM Ruff F401: ``json` imported but unused` tests/test_manifest.py:2 RUFF-F401
``json` imported but unused`
Fix: Auto-fix available: Remove unused import: ``json`` (applicability: safe)

MEDIUM Ruff F841: Local variable ``monitor`` is assigned to bu... ../test_integration_security.py:203 RUFF-F841
Local variable ``monitor`` is assigned to but never used
Fix: Auto-fix available: Remove assignment to unused variable ``monitor`` (applicability: unsafe)

MEDIUM Ruff F401: ``governance.lib.security.coordination_scor...` ../test_integration_security.py:14 RUFF-F401

``governance.lib.security.coordination_scorer.ToolCall` imported but unused`
Fix: Auto-fix available: Remove unused import: ``governance.lib.security.coordination_scorer.ToolCall`` (applicability: safe)

MEDIUM Ruff F401: ``unittest.mock.patch` imported but unused` `.../test_integration_security.py:8` RUFF-F401
``unittest.mock.patch` imported but unused`
Fix: Auto-fix available: Remove unused import: ``unittest.mock.patch`` (applicability: safe)

MEDIUM Ruff F401: ``governance.lib.security.identity_lifecycle.SessionCredential` imported but unused` `tests/test_identity_lifecycle.py:9` RUFF-F401
Fix: Auto-fix available: Remove unused import: ``governance.lib.security.identity_lifecycle.SessionCredential`` (applicability: safe)

MEDIUM Ruff F401: ``unittest.mock.patch` imported but unused` `tests/test_identity_lifecycle.py:5` RUFF-F401
``unittest.mock.patch` imported but unused`
Fix: Auto-fix available: Remove unused import: ``unittest.mock.patch`` (applicability: safe)

MEDIUM Ruff F401: ``governance.lib.security.guardian_agent.GuardianDecision` imported but unused` `tests/test_guardian_agent.py:8` RUFF-F401
Fix: Auto-fix available: Remove unused import: ``governance.lib.security.guardian_agent.GuardianDecision`` (applicability: safe)

MEDIUM Ruff F401: ``json` imported but unused` `...s/test_compliance_reporter.py:3` RUFF-F401
``json` imported but unused`
Fix: Auto-fix available: Remove unused import: ``json`` (applicability: safe)

MEDIUM Ruff F401: ``governance.lib.security.security_config.MetricConfig` imported but unused` `tests/test_behavioral_monitor.py:12` RUFF-F401
Fix: Auto-fix available: Remove unused import: ``governance.lib.security.security_config.MetricConfig`` (applicability: safe)

MEDIUM Ruff F401: ``governance.lib.security.behavioral_monitor.BaselineData` imported but unused` `tests/test_behavioral_monitor.py:9` RUFF-F401
Fix: Auto-fix available: Remove unused import: ``governance.lib.security.behavioral_monitor.BaselineData`` (applicability: safe)

MEDIUM Ruff F401: ``unittest.mock.patch` imported but unused` `tests/test_behavioral_monitor.py:5` RUFF-F401
``unittest.mock.patch` imported but unused`
Fix: Auto-fix available: Remove unused import: ``unittest.mock.patch`` (applicability: safe)

MEDIUM Ruff F401: ``math` imported but unused` `tests/test_behavioral_monitor.py:3` RUFF-F401
``math` imported but unused`
Fix: Auto-fix available: Remove unused import: ``math`` (applicability: safe)

MEDIUM Ruff F401: ``governance.lib.audit_bus.EventType` imported but unused` `tests/test_audit_bus.py:144` RUFF-F401
``governance.lib.audit_bus.EventType` imported but unused`
Fix: Auto-fix available: Remove unused import: ``governance.lib.audit_bus.EventType`` (applicability: safe)

MEDIUM Ruff F841: Local variable ``bus`` is assigned to but never used `tests/test_audit_bus.py:41` RUFF-F841
Local variable ``bus`` is assigned to but never used
Fix: Auto-fix available: Remove assignment to unused variable ``bus`` (applicability: unsafe)

MEDIUM Ruff F841: Local variable ``bus`` is assigned to but never used `tests/test_audit_bus.py:34` RUFF-F841
Local variable ``bus`` is assigned to but never used
Fix: Auto-fix available: Remove assignment to unused variable ``bus`` (applicability: unsafe)

MEDIUM Ruff F401: ``tempfile` imported but unused` `tests/test_audit_bus.py:4` RUFF-F401
``tempfile` imported but unused`
Fix: Auto-fix available: Remove unused import: ``tempfile`` (applicability: safe)

MEDIUM Ruff F401: ``os` imported but unused` `tests/test_audit_bus.py:3` RUFF-F401

`os` imported but unused

Fix: Auto-fix available: Remove unused import: `os` (applicability: safe)

MEDIUM Ruff F821: Undefined name `BPM\_ENV\_FILE` ...reate_security_collections.py:52 RUFF-F821
Undefined name `BPM\_ENV\_FILE`
Fix: See: <https://docs.astral.sh/ruff/rules/undefined-name>

MEDIUM Ruff F401: `json` imported but unused hooks/session_start.py:8 RUFF-F401
`json` imported but unused
Fix: Auto-fix available: Remove unused import: `json` (applicability: safe)

MEDIUM Ruff F841: Local variable `e` is assigned to but neve... hooks/pre_tool_check.py:129 RUFF-F841
Local variable `e` is assigned to but never used
Fix: Auto-fix available: Remove assignment to unused variable `e` (applicability: safe)

MEDIUM Ruff F401: `governance.lib.manifest.DEFAULT_RESTRICTI... hooks/pre_tool_check.py:33 RUFF-F401
`governance.lib.manifest.DEFAULT\_RESTRICTIVE\_MANIFEST` imported but unused
Fix: Auto-fix available: Remove unused import: `governance.lib.manifest.DEFAULT\_RESTRICTIVE\_MANIFEST` (applicability: safe)

MEDIUM Ruff F541: f-string without any placeholders hooks/post_tool_security.py:251 RUFF-F541
f-string without any placeholders
Fix: Auto-fix available: Remove extraneous `f` prefix (applicability: safe)

MEDIUM Ruff F541: f-string without any placeholders hooks/post_tool_security.py:250 RUFF-F541
f-string without any placeholders
Fix: Auto-fix available: Remove extraneous `f` prefix (applicability: safe)

MEDIUM Ruff F823: Local variable `timezone` referenced befor... hooks/memory_integrity_hook.py:139 RUFF-F823
Local variable `timezone` referenced before assignment
Fix: See: <https://docs.astral.sh/ruff/rules/undefined-local>

MEDIUM Ruff F823: Local variable `datetime` referenced befor... hooks/memory_integrity_hook.py:139 RUFF-F823
Local variable `datetime` referenced before assignment
Fix: See: <https://docs.astral.sh/ruff/rules/undefined-local>

MEDIUM Ruff F401: `os` imported but unused .../security/threat_detection.py:9 RUFF-F401
`os` imported but unused
Fix: Auto-fix available: Remove unused import: `os` (applicability: safe)

MEDIUM Ruff E402: Module level import not at top of file ...lib/security/qdrant_client.py:21 RUFF-E402
Module level import not at top of file
Fix: See: <https://docs.astral.sh/ruff/rules/module-import-not-at-top-of-file>

MEDIUM Ruff F401: `qdrant_client.http.exceptions.UnexpectedR... ...lib/security/qdrant_client.py:20 RUFF-F401
`qdrant\_client.http.exceptions.UnexpectedResponse` imported but unused
Fix: Auto-fix available: Remove unused import: `qdrant\_client.http.exceptions.UnexpectedResponse` (applicability: safe)

MEDIUM Ruff E402: Module level import not at top of file ...lib/security/qdrant_client.py:20 RUFF-E402
Module level import not at top of file
Fix: See: <https://docs.astral.sh/ruff/rules/module-import-not-at-top-of-file>

MEDIUM Ruff E402: Module level import not at top of file ...lib/security/qdrant_client.py:19 RUFF-E402
Module level import not at top of file
Fix: See: <https://docs.astral.sh/ruff/rules/module-import-not-at-top-of-file>

MEDIUM Ruff F401: `numpy` imported but unused .../security/memory_integrity.py:18 RUFF-F401

`numpy` imported but unused
Fix: Auto-fix available: Remove unused import: `numpy` (applicability: safe)

MEDIUM Ruff F401: `os` imported but unused
`os` imported but unused
.../security/memory_integrity.py:11 RUFF-F401
Fix: Auto-fix available: Remove unused import: `os` (applicability: safe)

MEDIUM Ruff F401: `json` imported but unused
`json` imported but unused
.../security/memory_integrity.py:9 RUFF-F401
Fix: Auto-fix available: Remove unused import: `json` (applicability: safe)

MEDIUM Ruff F401: `hashlib` imported but unused
`hashlib` imported but unused
.../security/memory_integrity.py:8 RUFF-F401
Fix: Auto-fix available: Remove unused import: `hashlib` (applicability: safe)

MEDIUM Ruff F841: Local variable `severity` is assigned to b...
Local variable `severity` is assigned to but never used
...ib/security/guardian_agent.py:101 RUFF-F841
Fix: Auto-fix available: Remove assignment to unused variable `severity` (applicability: unsafe)

MEDIUM Ruff F401: `dataclasses.field` imported but unused
`dataclasses.field` imported but unused
...ib/security/guardian_agent.py:13 RUFF-F401
Fix: Auto-fix available: Remove unused import: `dataclasses.field` (applicability: safe)

MEDIUM Ruff F401: `collections.defaultdict` imported but unused
`collections.defaultdict` imported but unused
...ib/security/guardian_agent.py:12 RUFF-F401
Fix: Auto-fix available: Remove unused import: `collections.defaultdict` (applicability: safe)

MEDIUM Ruff F401: `fastapi.Response` imported but unused
`fastapi.Response` imported but unused
...lib/security/dashboard_api.py:19 RUFF-F401
Fix: Auto-fix available: Remove unused import: `fastapi.Response` (applicability: safe)

MEDIUM Ruff F401: `pathlib.Path` imported but unused
`pathlib.Path` imported but unused
...lib/security/dashboard_api.py:15 RUFF-F401
Fix: Auto-fix available: Remove unused import: `pathlib.Path` (applicability: safe)

MEDIUM Ruff F401: `functools.wraps` imported but unused
`functools.wraps` imported but unused
...lib/security/dashboard_api.py:14 RUFF-F401
Fix: Auto-fix available: Remove unused import: `functools.wraps` (applicability: safe)

MEDIUM Ruff F401: `uuid` imported but unused
`uuid` imported but unused
...lib/security/dashboard_api.py:12 RUFF-F401
Fix: Auto-fix available: Remove unused import: `uuid` (applicability: safe)

MEDIUM Ruff F401: `time` imported but unused
`time` imported but unused
...lib/security/dashboard_api.py:11 RUFF-F401
Fix: Auto-fix available: Remove unused import: `time` (applicability: safe)

MEDIUM Ruff F401: `json` imported but unused
`json` imported but unused
...lib/security/dashboard_api.py:8 RUFF-F401
Fix: Auto-fix available: Remove unused import: `json` (applicability: safe)

MEDIUM Ruff F401: `typing.Optional` imported but unused
`typing.Optional` imported but unused
...curity/coordination_scorer.py:14 RUFF-F401
Fix: Auto-fix available: Remove unused import: `typing.Optional` (applicability: safe)

MEDIUM Ruff F401: `dataclasses.field` imported but unused
...curity/coordination_scorer.py:12 RUFF-F401

`dataclasses.field` imported but unused

Fix: Auto-fix available: Remove unused import: `dataclasses.field` (applicability: safe)

MEDIUM Ruff F401: `governance.lib.security.security\_config.M...`
`governance.lib.security.security\_config.MetricConfig` imported but unused
Fix: Auto-fix available: Remove unused import: `governance.lib.security.security\_config.MetricConfig` (applicability: safe)

MEDIUM Ruff F401: `dataclasses.field` imported but unused
`dataclasses.field` imported but unused
Fix: Auto-fix available: Remove unused import: `dataclasses.field` (applicability: safe)

opengrep

SAST | 3 findings | Multi-language static analysis for security vulnerabilities

Severity	Title	File	CWE / Rule
MEDIUM	python-logger-credential-disclosure Detected a python logger call with a potential hardcoded secret "validate_scope: no credential for session %s — identity lifecycle not bootstrapped, allowing" being logged. This may lead to secret credentials being exposed. Make sure that the logger is not logging sensitive information.	...ecurity/identity_lifecycle.py:363	CWE-532: Insertion of

requires login

Fix: Review this finding and apply the appropriate fix based on the description: Detected a python logger call with a potential hardcoded secret "validate_scope: no credential for session %s — identity lifecycle not bootstrapped, allowing" being logged.
This may lead to secret cre

OWASP: A09:2021 - Security Logging and Monitoring Failures | Rule: python.lang.security.audit.logging.logger-credential-leak.python-logger-credential-disclosure

MEDIUM wildcard-cors
CORS policy allows any origin (using wildcard '*'). This is insecure and should be avoided.

requires login

Fix: Review this finding and apply the appropriate fix based on the description: CORS policy allows any origin (using wildcard '*').
This is insecure and should be avoided.

OWASP: A05:2021 - Security Misconfiguration | Rule: python.fastapi.security.wildcard-cors.wildcard-cors

INFO dependabot-missing-cooldown
This Dependabot configuration does not set a cooldown period. Newly published packages can be malicious or unstable. Add a `cooldown` block with `default-days: 7` to each `package-ecosystem` entry under `updates` to wait 7 days before proposing updates to newly published package versions. Reference:

...

requires login

Fix: Review this finding and apply the appropriate fix based on the description: This Dependabot configuration does not set a cooldown period. Newly published packages can be malicious or unstable. Add a `cooldown` block with `default-days: 7` to each `package-ecosystem` entry und

OWASP: A08:2021 - Software and Data Integrity Failures | Rule: package_managers.dependabot.dependabot-missing-cooldown.dependabot-missing-cooldown

syft

SBOM | 7 findings | Software bill of materials generator for supply chain visibility

Severity	Title	File	CWE / Rule
LOW	Unknown License: setuptools@83.0.0	/requirements.txt	SBOM-LICENSE-UNKNOWN

Package setuptools has no license information. This may indicate a compliance risk.

Package: setuptools
Version: 83.0.0
Type: python

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW Unknown License: pyyaml@6.0.2 /requirements.txt SBOM-LICENSE-UNKNOWN
Package pyyaml has no license information. This may indicate a compliance risk.

Package: pyyaml
Version: 6.0.2
Type: python

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW Unknown License: ossf/scorecard-action@v2.4.0 /.github/workflows/scorecard.yml SBOM-LICENSE-UNKNOWN
Package ossf/scorecard-action has no license information. This may indicate a compliance risk.

Package: ossf/scorecard-action
Version: v2.4.0
Type: github-action

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW Unknown License: github/codeql-action/upload-sarif@41... /.github/workflows/scorecard.yml SBOM-LICENSE-UNKNOWN
Package github/codeql-action/upload-sarif has no license information. This may indicate a compliance risk.

Package: github/codeql-action/upload-sarif
Version: 4187e74d05793876e9989daffde9c3e66b4acd07
Type: github-action

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW Unknown License: actions/setup-python@a26af69be951a21... /.github/workflows/ci.yml SBOM-LICENSE-UNKNOWN
Package actions/setup-python has no license information. This may indicate a compliance risk.

Package: actions/setup-python
Version: a26af69be951a213d495a4c3e4e4022e16d87065
Type: github-action

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW Unknown License: actions/checkout@11d5960a326750d5838... /.github/workflows/scorecard.yml SBOM-LICENSE-UNKNOWN
Package actions/checkout has no license information. This may indicate a compliance risk.

Package: actions/checkout
Version: 11d5960a326750d5838078e36cf38b85af677262
Type: github-action

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW

Unknown License: actions/checkout@11d5960a326750d5838... /github/workflows/ci.yml
Package actions/checkout has no license information. This may indicate a compliance risk.

SBOM-LICENSE-UNKNOWN

Package: actions/checkout
Version: 11d5960a326750d5838078e36cf38b85af677262
Type: github-action

Fix: Verify the license for this package before using in production.
OWASP: A08:2021-Software and Data Integrity Failures

trivy

SCA | 1 finding | Container image and filesystem vulnerability scanner

Severity	Title	File	CWE / Rule
LOW	License Compliance: Apache-2.0 in Package uses license Apache-2.0 (category: notice). Review for compliance with your organization's license policy.	LICENSE	LICENSE-Apache-2.0

Package:
License: Apache-2.0
Category: notice

Fix: Review this finding and apply the appropriate fix based on the description: Package uses license Apache-2.0 (category: notice). Review for compliance with your organization's license policy.
OWASP: A06:2021-Vulnerable and Outdated Components

typos

Code Quality | 1 finding | Source code spell checker

Severity	Title	File	CWE / Rule
INFO	Typo: "generat" should be "generate, general" Found typo "generat" in typo. Suggested corrections: generate, general.	hooks/memory_integrity_hook.py:41	TYPOS-SPELLING
Fix:	Replace "generat" with "generate, general".		

Codebase Coverage (68 files analyzed)

This scan analyzed 68 files using 11 security tools across 8 testing categories. Each scanner targets files relevant to its analysis domain (e.g., SAST scanners analyze source code, SCA scanners analyze dependency manifests).

Files by Language:

Python: 46 files

Config: 13 files

Markdown: 5 files

Shell: 1 files

Files by Extension:

.py: 46

.json: 4

.md: 4

.yaml: 4

.yml: 3

.toml: 2

.other: 2

.sh: 1

.gitignore: 1

.txt: 1

Per-Scanner File Coverage:

Scanner	Category	Files Analyzed	Scope
---------	----------	----------------	-------

trivy	SCA	2	Scanned 2 target(s): pip
gitLeaks	Secrets	68	Working directory scanned for 150+ secret p...
opengrep	SAST	47	Multi-language SAST with auto, security-aud...
checkov	IaC	13	IaC security analysis — 0 files, 0 checks (...)
grype	SCA	68	SCA analysis: 0 unique CVEs across 0 vulner...
syft	SBOM	7	SBOM of 7 packages across 1 language(s): py...
package-validator	AI Code Quality	1	Validated 5 packages across 1 dependency fi...
oxlint	Code Quality	47	JavaScript (.js, .jsx) and TypeScript (.ts,...)
ruff	Code Quality	46	Python linting and security analysis via Ruff
actionlint	CI/CD Security	13	.github/workflows/*.yaml files
jscpd	Code Quality	46	All source files across supported languages
typos	Code Quality	68	All files in project directory

Files with Findings (30):

File Path	Findings	Scanners
governance/lib/security/dashboard_api.py	6	ruff
tests/test_audit_bus.py	5	ruff
tests/test_manifest.py	4	ruff
governance/lib/security/qdrant_client.py	4	ruff
tests/test_behavioral_monitor.py	4	ruff
governance/lib/security/memory_integrity.py	4	ruff
tests/test_integration_security.py	3	ruff
/.github/workflows/scorecard.yml	3	syft
tests/test_trust_broker.py	3	ruff
hooks/memory_integrity_hook.py	3	ruff, typos
governance/lib/security/guardian_agent.py	3	ruff
tests/test_policy_engine.py	3	ruff
hooks/post_tool_security.py	2	ruff
/requirements.txt	2	syft
governance/lib/security/behavioral_monitor.py	2	ruff
governance/lib/security/coordination_scorer.py	2	ruff
/.github/workflows/ci.yml	2	syft
hooks/pre_tool_check.py	2	ruff
tests/test_identity_lifecycle.py	2	ruff
tests/test_memory_governor.py	2	ruff
governance/lib/security/threat_detection.py	1	ruff
tests/test_compliance_reporter.py	1	ruff
tests/test_guardian_agent.py	1	ruff
/scan-target/governance/lib/security/dashboard_api.py	1	opengrep
LICENSE	1	trivy
/scan-target/governance/lib/security/identity_lifecycle.py	1	opengrep
/scan-target/.github/dependabot.yml	1	opengrep

tests/test_memory_integrity.py	1	ruff
scripts/create_security_collections.py	1	ruff
hooks/session_start.py	1	ruff

Software Bill of Materials (7 packages)

Package types: github-action: 5 | python: 2

Top licenses: Unknown (7)

Package	Version	Type	Language	License
actions/checkout	11d5960a326750	github-actio	-	Unknown
actions/checkout	11d5960a326750	github-actio	-	Unknown
actions/setup-python	a26af69be951a2	github-actio	-	Unknown
github/codeql-action/upload-sarif	4187e74d057938	github-actio	-	Unknown
ossf/scorecard-action	v2.4.0	github-actio	-	Unknown
pyyaml	6.0.2	python	python	Unknown
setuptools	83.0.0	python	python	Unknown